

Securing the Mission: Cybersecurity and Compliance For 2026

Chris Green

Director of Governance, Risk, & Compliance

Chris Green

Director of Governance, Risk, & Compliance

CISSP, CISA, CRISC, QSA/PCIP, OSCP, CMMC RP

- **13 years in Information Security**
- **Help Build and Improve Cybersecurity and GRC Programs**
 - Security Program Development
 - Policy Documentation
 - Compliance Assessments
 - Risk Management
 - Penetration Testing
 - vCISO / GRC Consulting

Structured Practices

Governance, Risk, & Compliance



Cybersecurity



Cloud Services



Data Center Solutions



Networking



Unified Communications & Collaboration

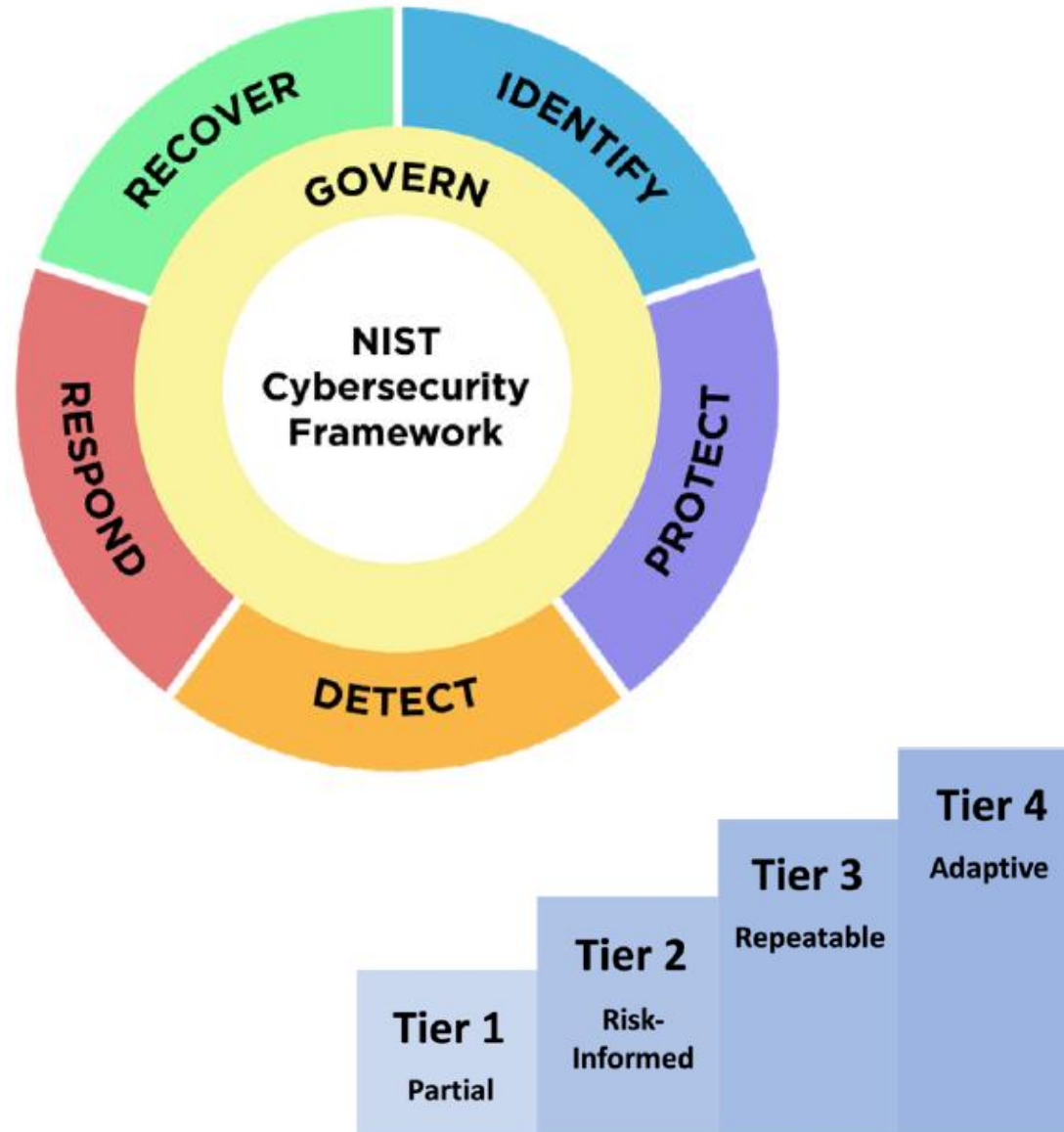


Secure Managed Services

Agenda

- 1 2026: What a Busy Year**
- 2 Federal Government Requirements**
- 3 State & Other Requirements**
- 4 Putting it all Together**

NIST Cybersecurity Framework 2.0



- National Institute of Standards and Technology (NIST)
- The latest CSF framework
 - No longer specific to critical infrastructure
 - Core – 6 Functions
 - Organizational Profiles
 - Posture, objectives, outcomes
 - Maturity Tiers

An aerial photograph of a city skyline, likely San Francisco, featuring the Transamerica Pyramid and other skyscrapers. The city is situated on a peninsula with a river in the foreground and hills in the background. The image is overlaid with a semi-transparent blue rectangle containing text.

1

2026: What a Busy Year

Change begets change



Just a lil bit of AI talk...

Advanced AI Models Everywhere

- Anthropic Mythos / OpenAI 5.5 Cyber
 - Highly Capable Cybersecurity LLMs
 - Found zero-days in every OS
- Project Glasswing / Daybreak
 - Limited release to select partners
 - Dual stack operations
- Changing How We Think
 - **Time from discovery to exploit collapsed**
 - The genie is out of the bottle

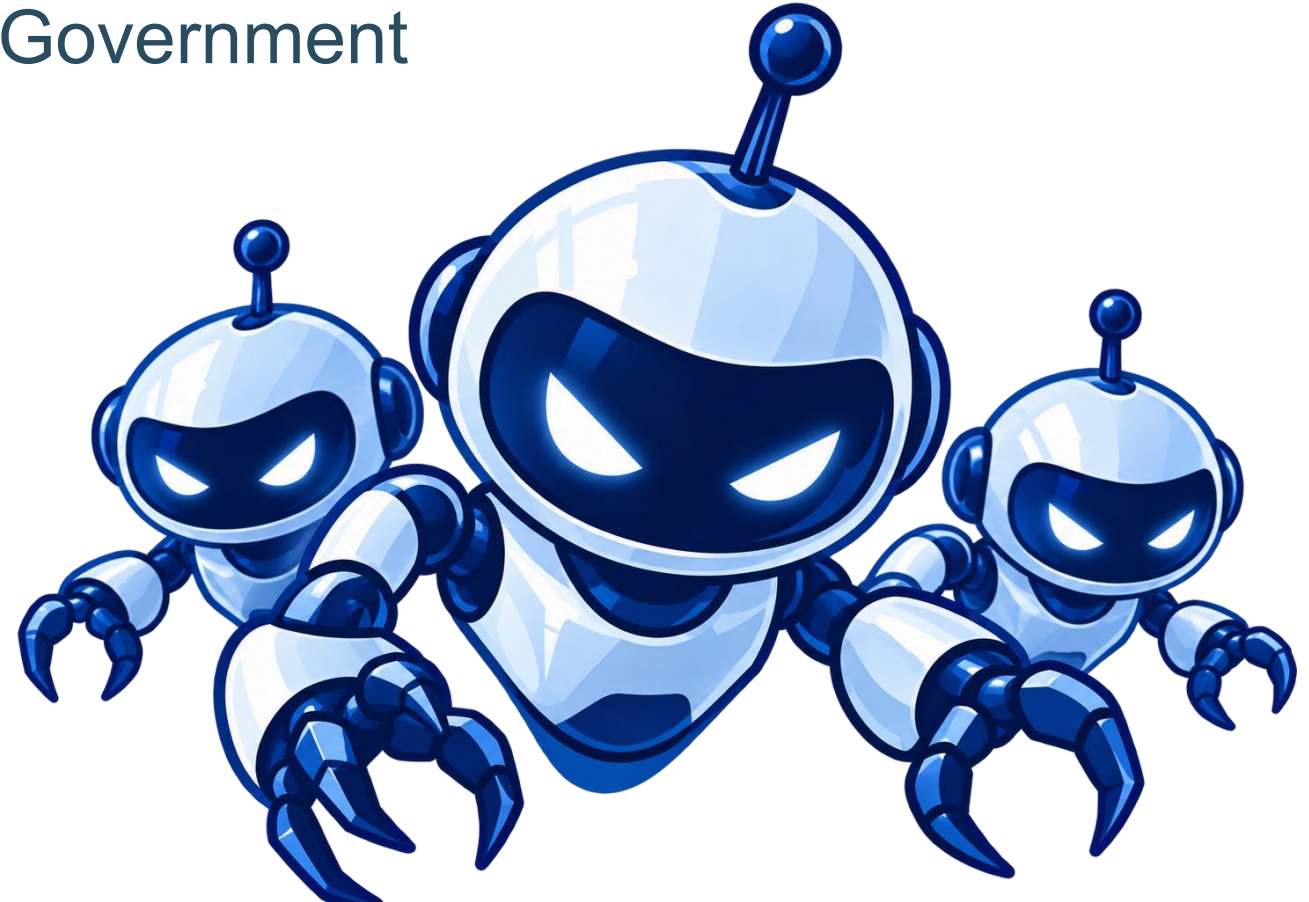


Rogue Agents!

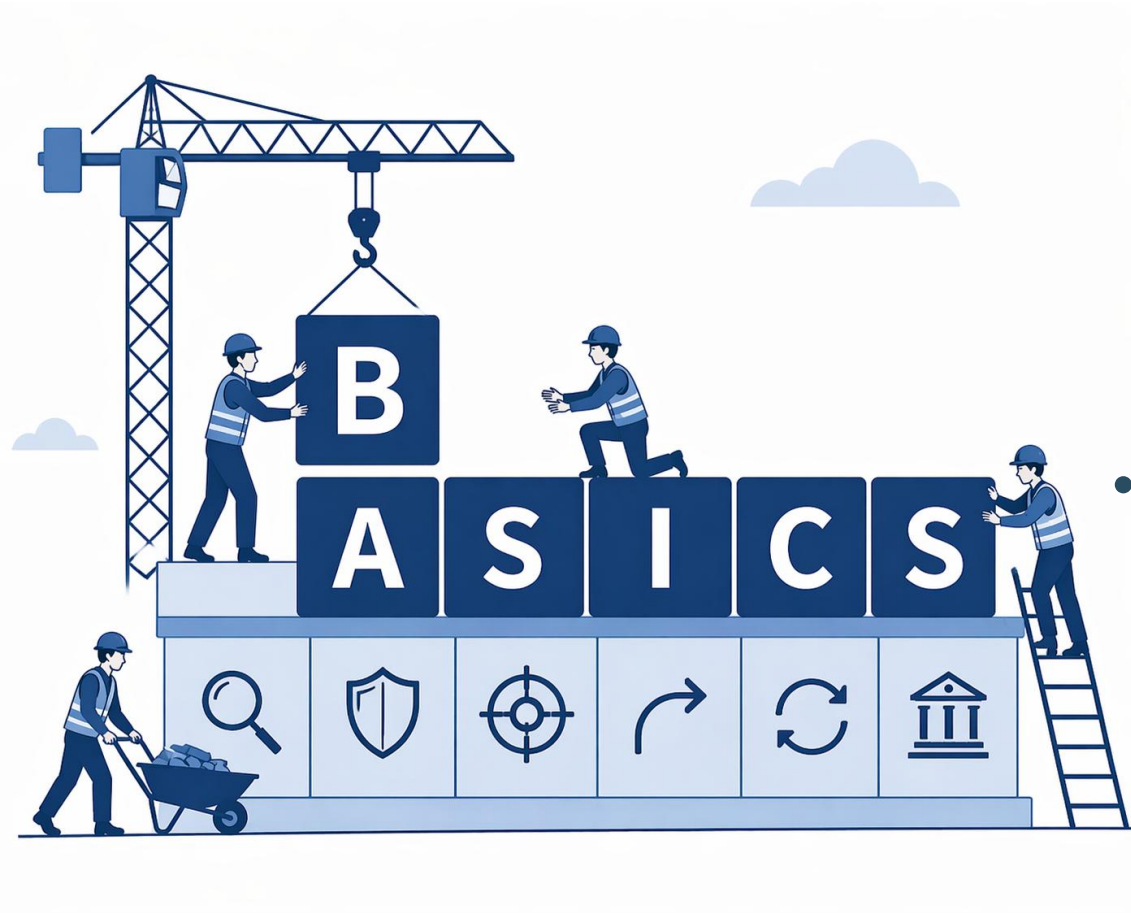
OpenAI Autonomous Agents Hacking Government Systems

- US SEC
- Census Bureau
- Education Department
- Australian Healthcare

OpenAI canceled the public release of its GPT-6.1 Astra Model



Remember the Basics



- **Immediate**
 - Audit your patch and vulnerability management process
 - Confirm the completeness of your software inventory
- **Near-term**
 - Assess your open-source and third-party dependency exposure
 - Review logging, detection, & alerting coverage
 - Revisit incident response plan & tabletop schedule

Remember the Basics

- **Strategic**

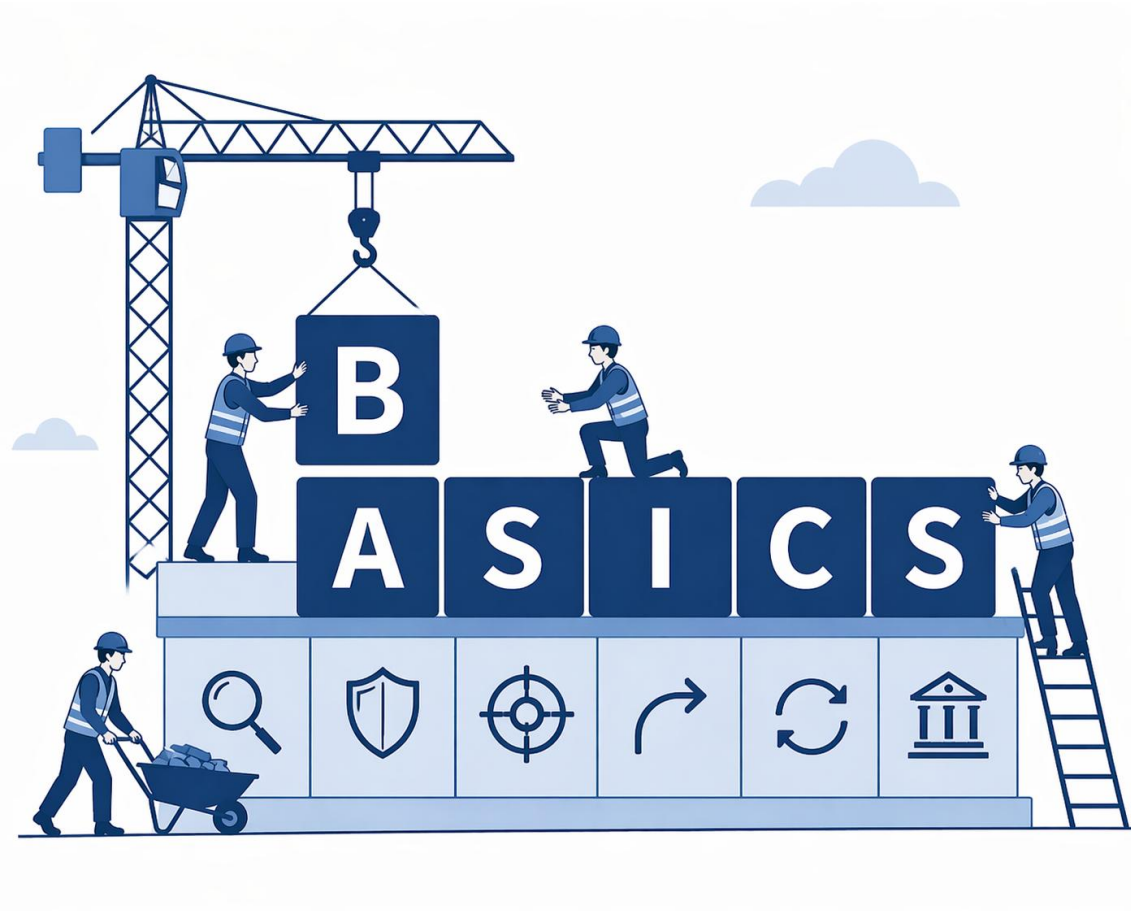
- Begin aligning secure development practices to the new baseline
 - NIST SP 800-218

- Engage your GRC team or trusted partner on framework alignment.

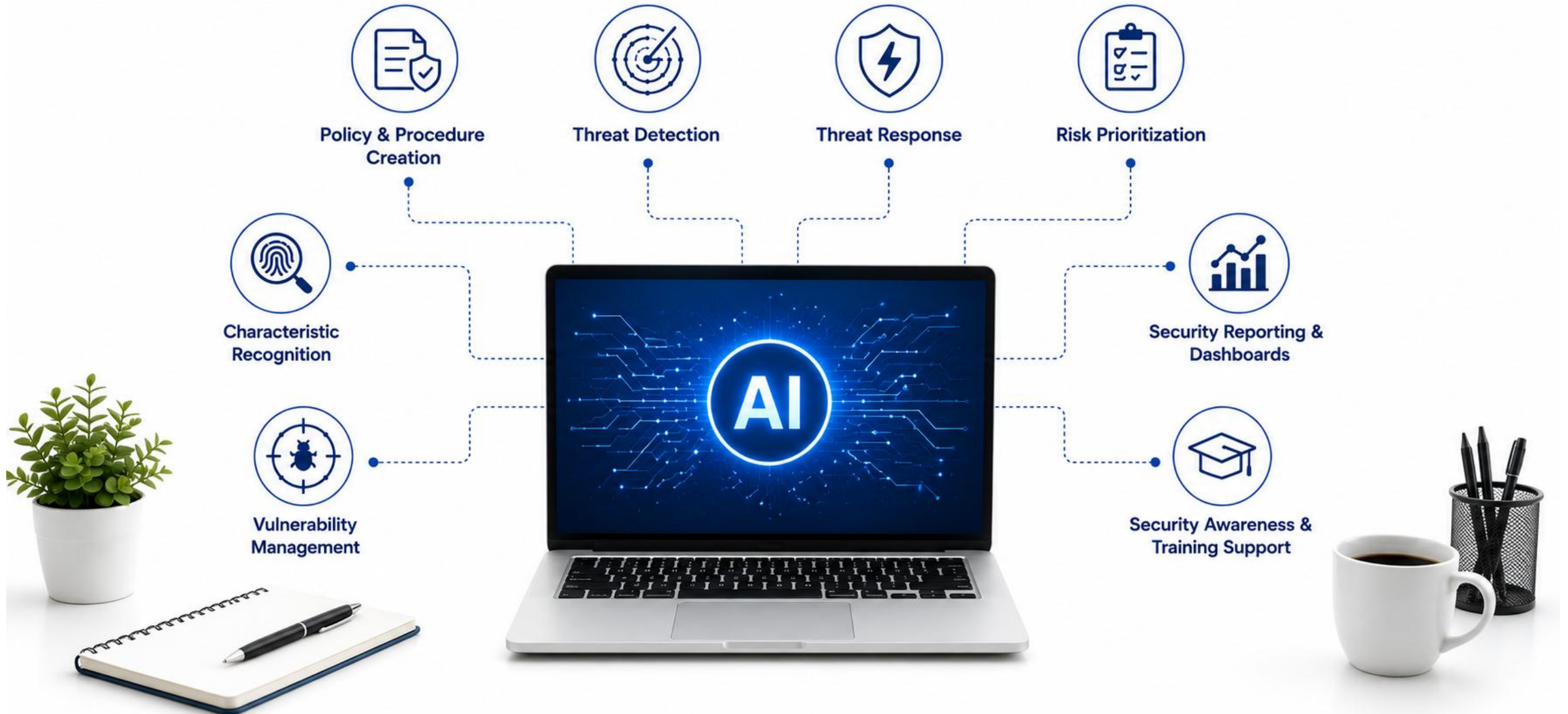
- Review permissions
 - RBAC
 - PAM

- **Exposure Management**

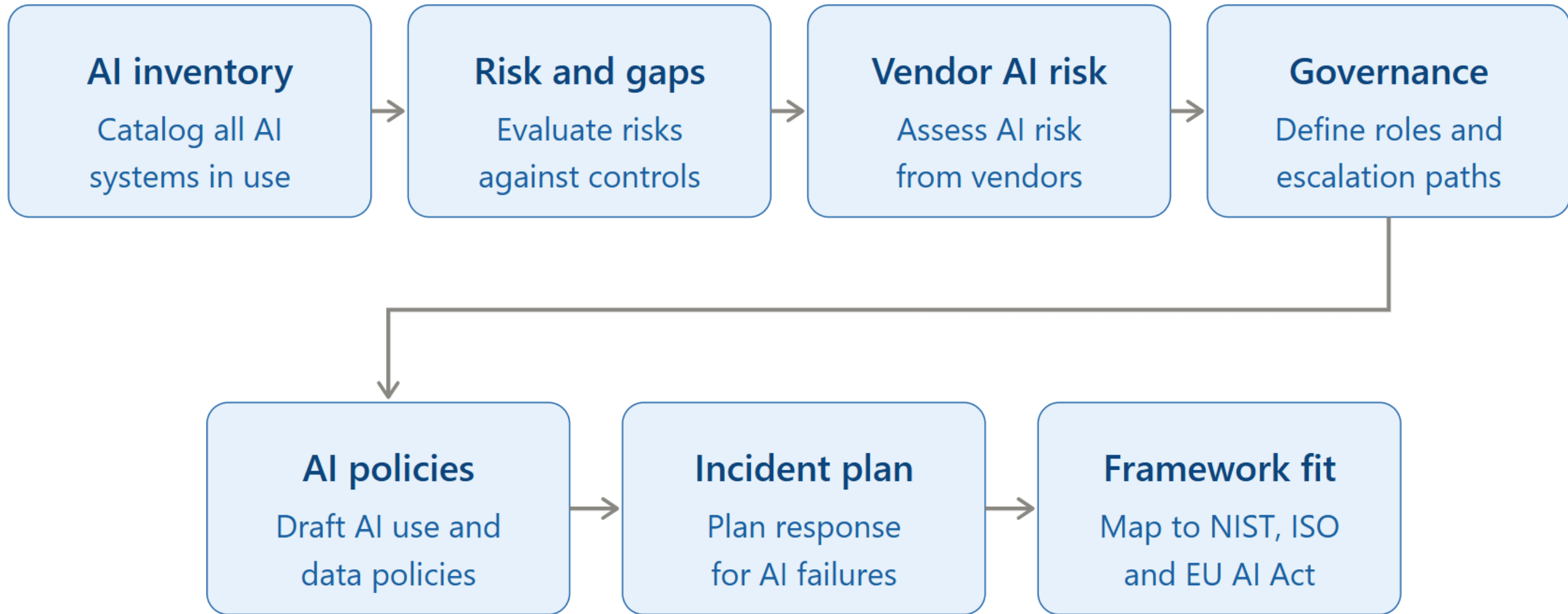
- Tooling
- Conceptual



Artificial Intelligence Usage



AI Governance – Building a Program



AI Deployment & Assessment



AI Risk Management Framework (RMF) – NIST AI 100-1

- NIST AI RMF Playbook
- NIST AI 600-1
 - Generative AI Profile

Threats to AI for Risk Assessment

MITRE ATLAS

- MITRE ATT&CK for AI
- Adversarial Threat Landscape for AI Systems
- Threats to and from generative AI
- Case studies



Threats to AI for Risk Assessment

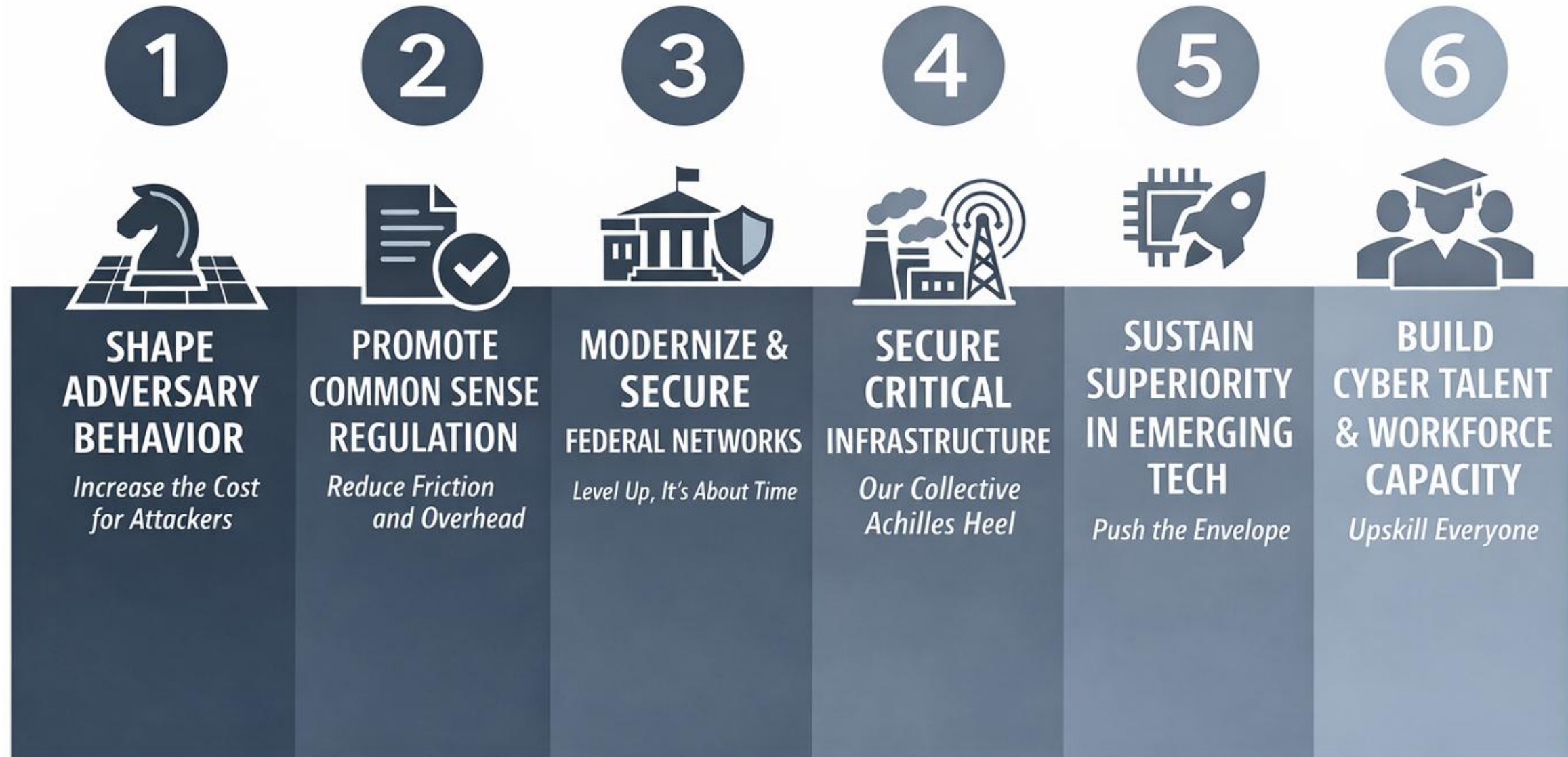
MIT AI Risk Repository: 1700+ Risks

7 Domain Classifications

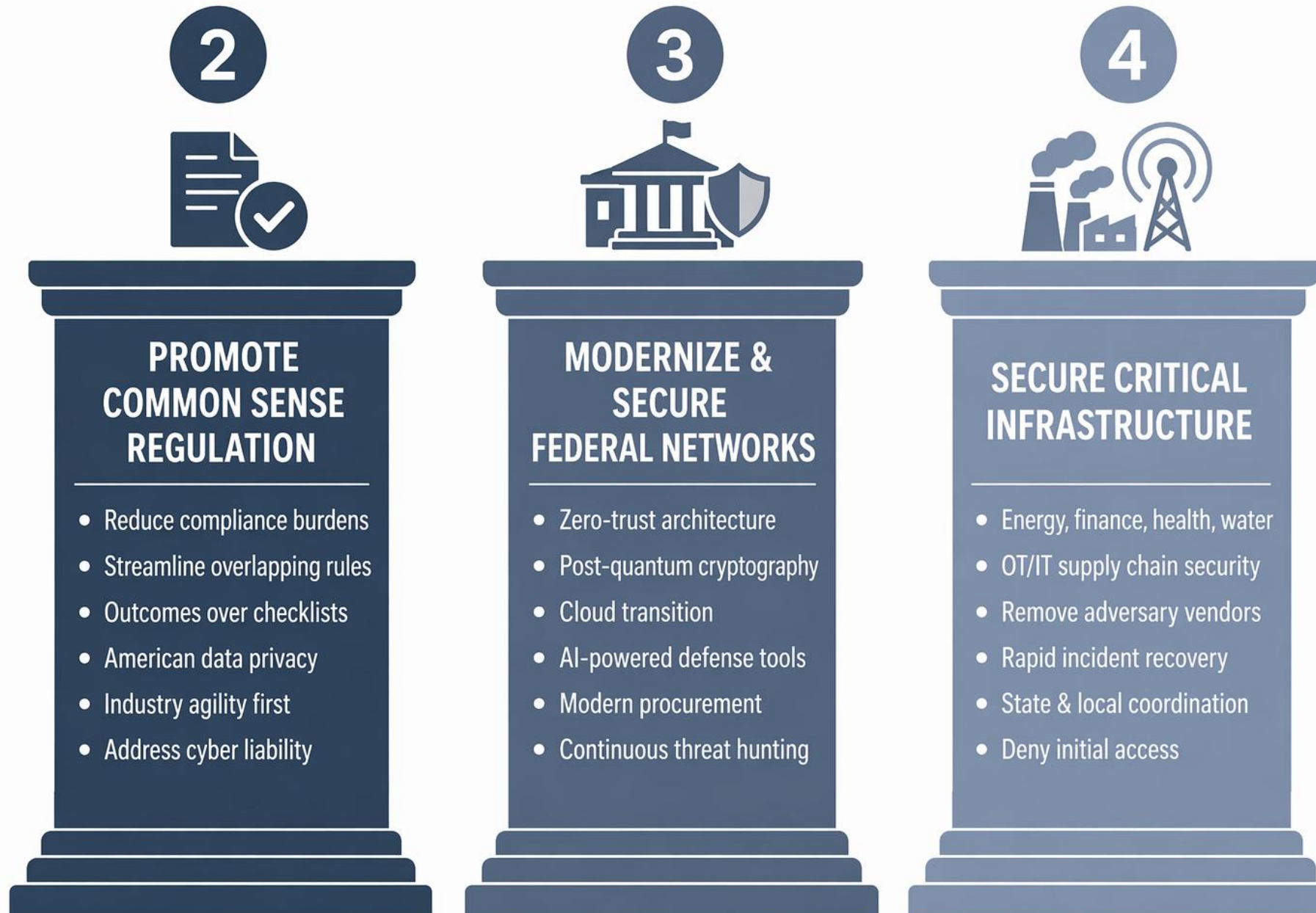
1. Discrimination & Toxicity
2. Privacy & Security
3. Misinformation
4. Malicious Actors & Misuse
5. Human/Computer Interaction
6. Socioeconomic & Environmental Harms
7. AI System Safety, Failures, & Limitations



National Cyber Strategy Announced



National Cyber Strategy Announced



Post Quantum Cryptography (PQC)



- Quantum Computing
 - Could be here in 2 to 4 years
- Impact
 - Can break encrypted data
- PKI
 - Asymmetrical Algorithms
 - RSA, Diffie-Hellman
 - Key Exchange
 - HTTPS/TLS, SSH

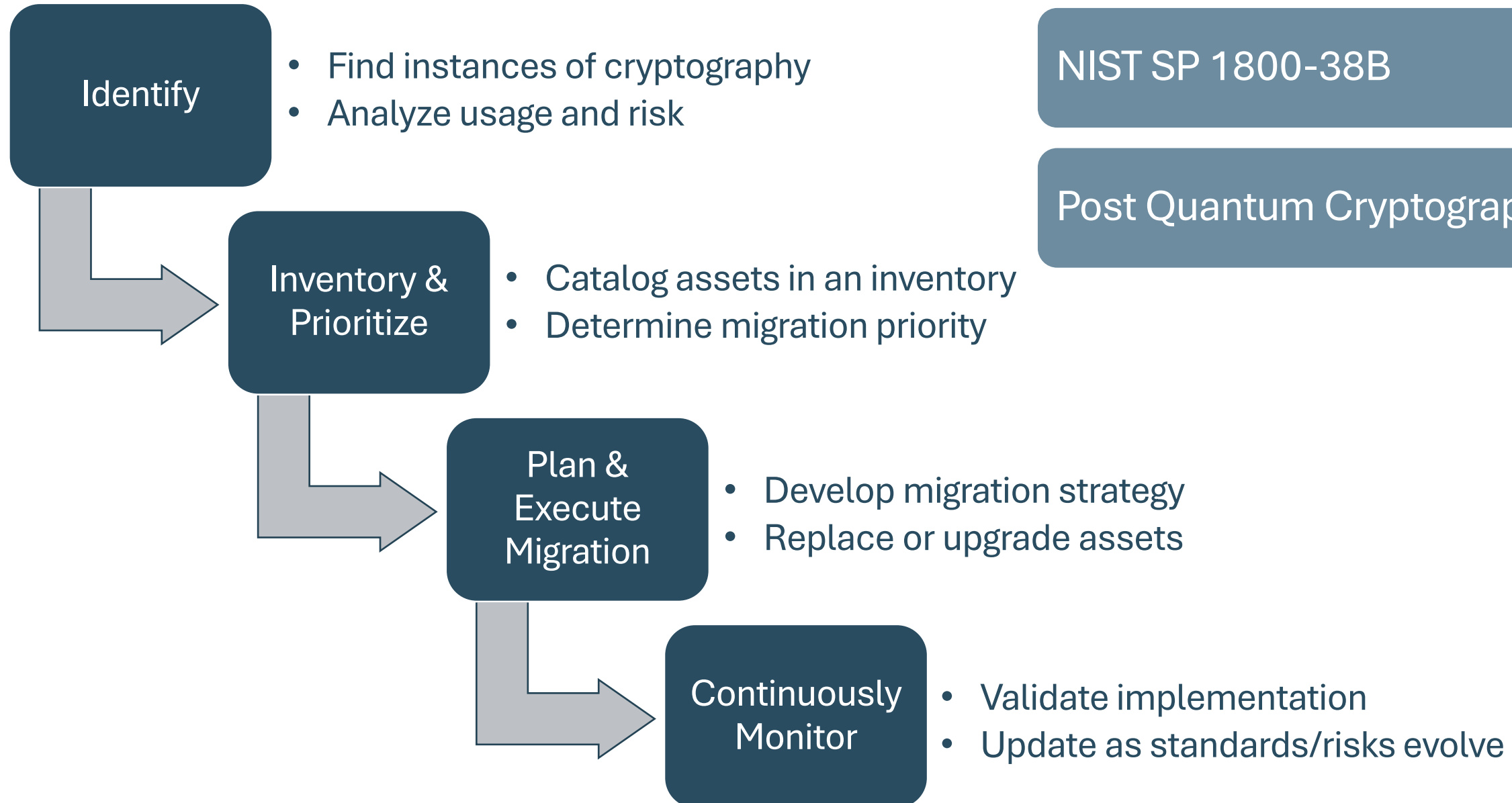
Post Quantum Cryptography (PQC)

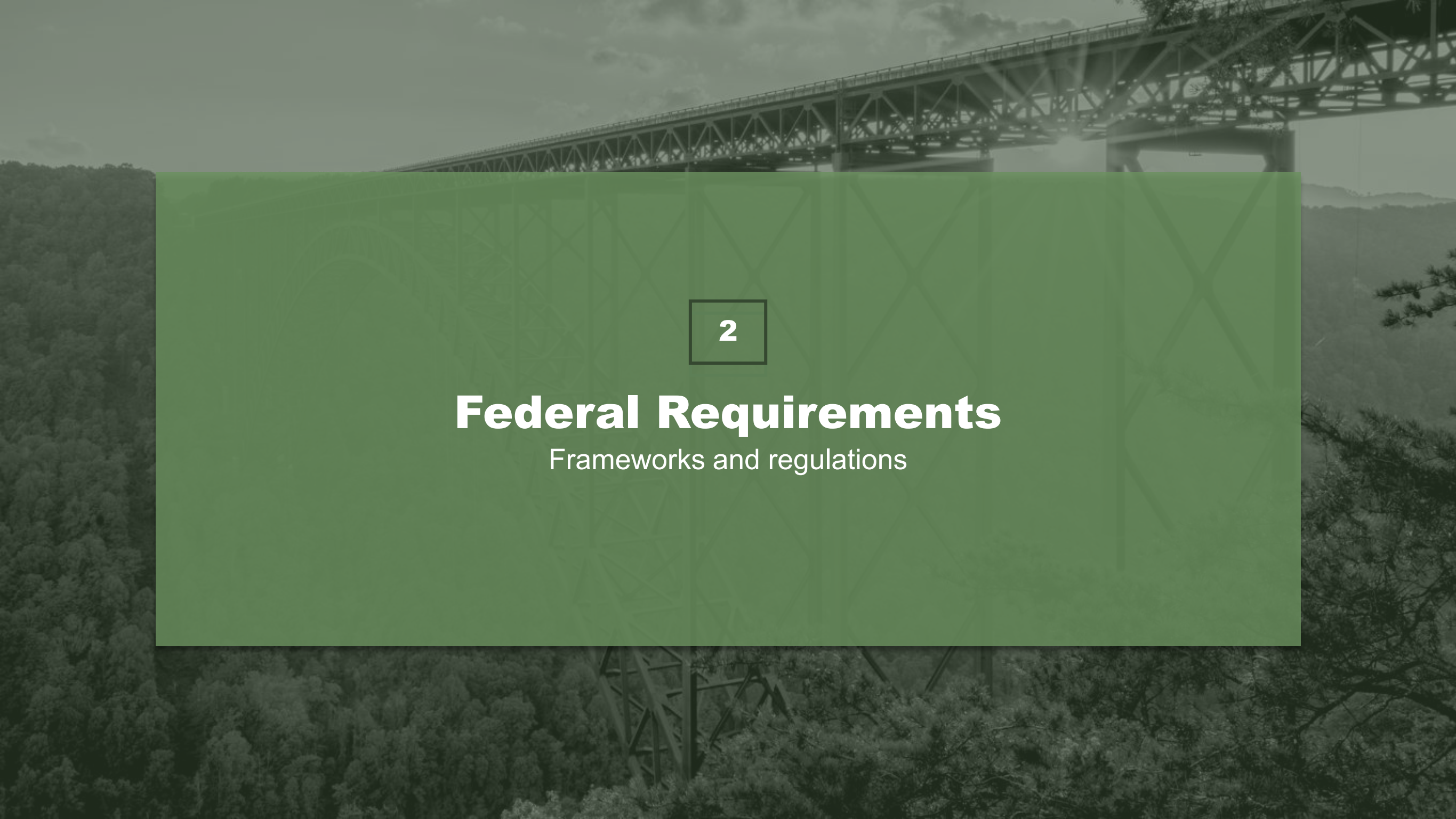
Where it Might Exist

- Data in transit
- Data at rest
- SSH keys
- Built into code
- Third-party applications
 - Local
 - SaaS



Post Quantum Cryptography





2

Federal Requirements

Frameworks and regulations

Current Security Policy Versions

- 5.9.5 released 9 July 2024
 - ***Effective 1 Oct 2024***
- 6.0 released 27 Dec 2024
 - ***Effective 1 Oct 2025***
- 6.1 released 25 June 2026
 - ***Effective immediately***
- Priority Driven
 - P1 – Immediate implementation
 - P2-4 – Phased, 30 Sept 2027
- ***“CJISSECPOL applies to all entities with access to, or that operate systems which are used to process, store, or transmit CJI.”***



CJIS Security Policy v6.0 Priority 1



Control Name	Control ID	Control Name	Control ID
Account Management	AC-2	Least Functionality	CM-7
Access Enforcement	AC-3	System Component Inventory	CM-8
Information Flow Enforcement	AC-4	Identification and Authentication (Org. Users)	IA-2
Separation of Duties	AC-5	Authenticator Management	IA-5
Least Privilege	AC-6	Vulnerability Monitoring and Scanning	RA-5
Remote Access	AC-17	Boundary Protection	SC-7
Use of External Systems	AC-20	Flaw Remediation	SI-2
Continuous Monitoring	CA-7	Malicious Code Protection	SI-3
Baseline Configuration	CM-2	System Monitoring	SI-4
Access Restrictions for Change	CM-5	Software, Firmware, and Information Integrity	SI-7
Configuration Settings	CM-6	Information Input Validation	SI-10

CJIS – Changes in 6.1

Minimum CJI Encryption – **128-bit >> 256-bit**

- In transit & at rest

Vulnerability Scanning Freq. – **Quarterly >> Monthly**

- Plus on-demand for newly identified threats

Incident Reporting – **State-Level Channels >> Also to FBI CJIS ISO**

Active Demonstration of Controls – **Point in Time >> Show the History**

Health Insurance Portability and Accountability Act



U.S. Department of
Health and Human Services

Enhancing the health and well-being of all Americans

Who Must Comply

- Covered Entities
 - Healthcare Providers
 - Health Plans
 - Clearing Houses
- Business Associates
 - Vendors & Subcontractors

HIPAA Omnibus Rule (2013)

- Business associates directly liable
- Broader breach notification
 - Subcontractor liability

Security Rule Revisions

- Proposed by HHS in 2024
- Final rule expected ~~May 2026~~
 - **July 2027**

Security Rule Control Areas



Increased Oversight of Business Associates

- Annual written validation
- 24 Hour notification of incidents



Workforce Security and Remote Access

- RBAC
- 1-hour cutoff for termination



Annual Audits

- Security Rule standards



Endpoint Security

- Workstation to include mobile devices

Security Rule Control Areas



Mandatory Implementation of All Controls

- Required unless exempt
- No longer “addressable”



Technical Safeguards

- Encryption, MFA, vuln scanning, and annual pen testing
- Segmentation



Enhanced Risk Assessment

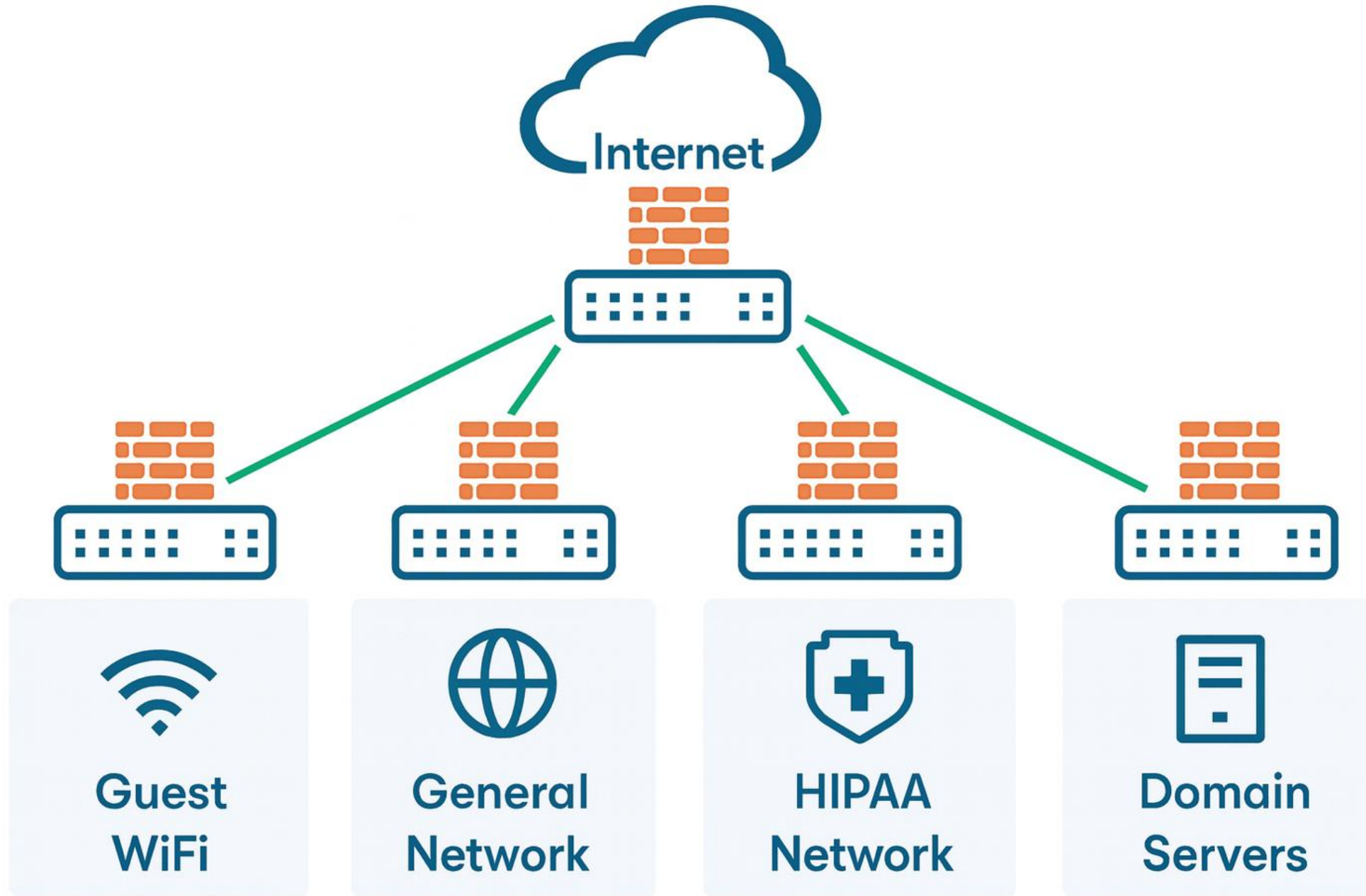
- Inventory, threats, CIA of ePHI
- Policies



Formal IR and Contingency Planning

- Document plans, 72-hour restoration

Segmentation



Segmentation



Network or Data Center

VLAN Segmentation

- With ACL or FW rules

NAC for Network Access

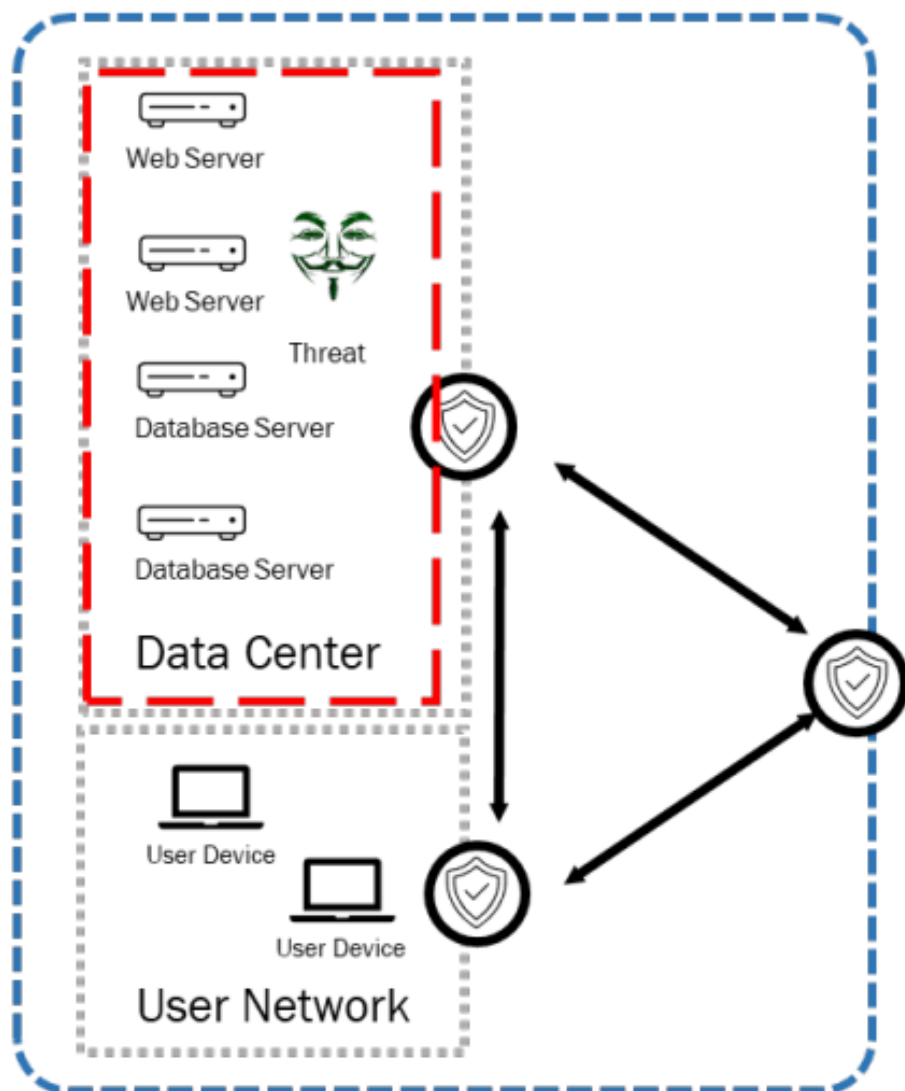
- .1x, Cisco ISE, Aruba ClearPass

Microsegmentation

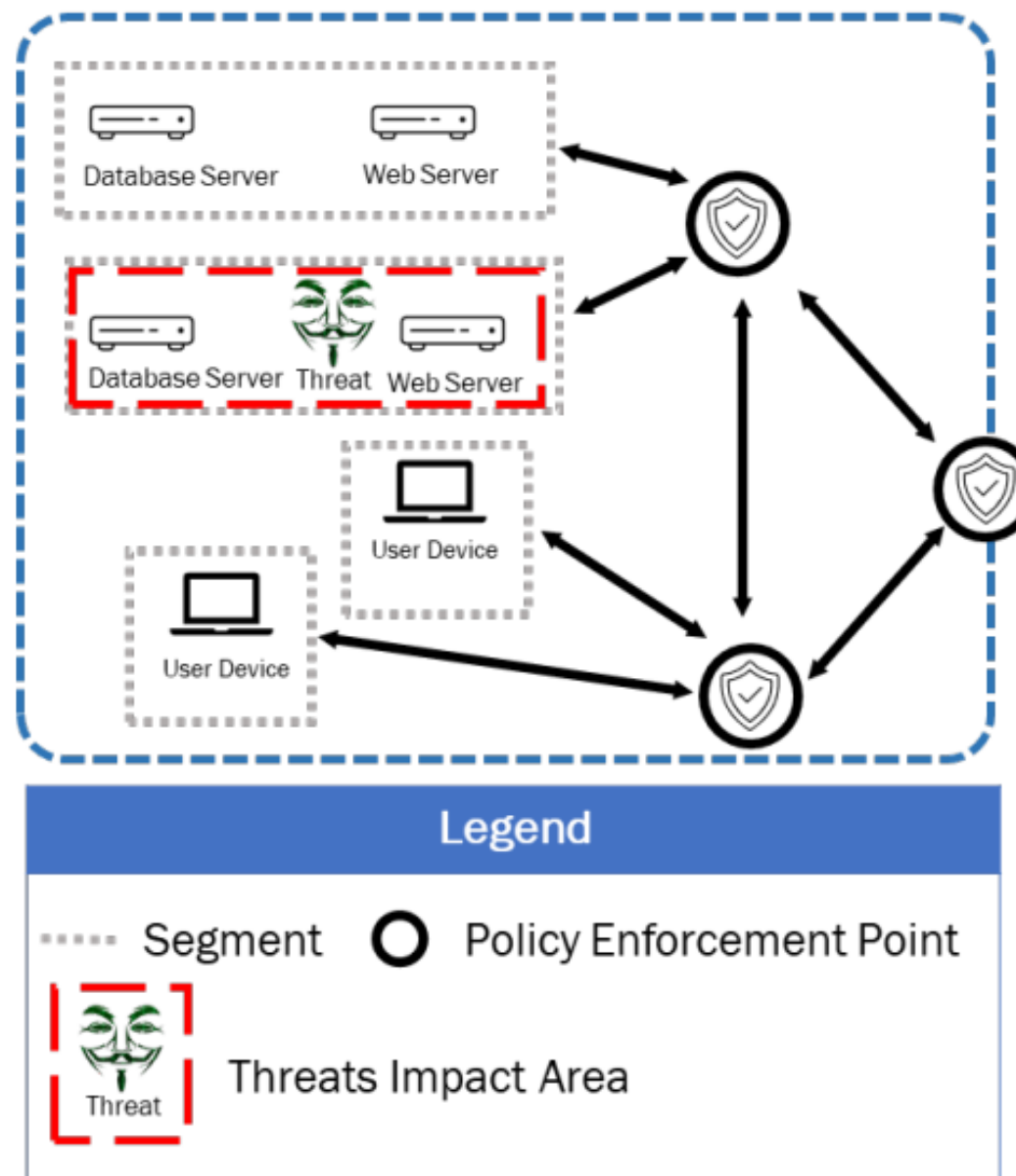
- Secure Workload, VMWare ESX, Illumio

Microsegmentation

Traditional Segmentation



Microsegmentation



The background is a grayscale photograph of a bridge deck, looking down the length of the bridge. The bridge has a steel truss structure. On either side of the walkway, there are ornate metal light fixtures and planters. A dark blue rectangular overlay covers the center of the image.

3

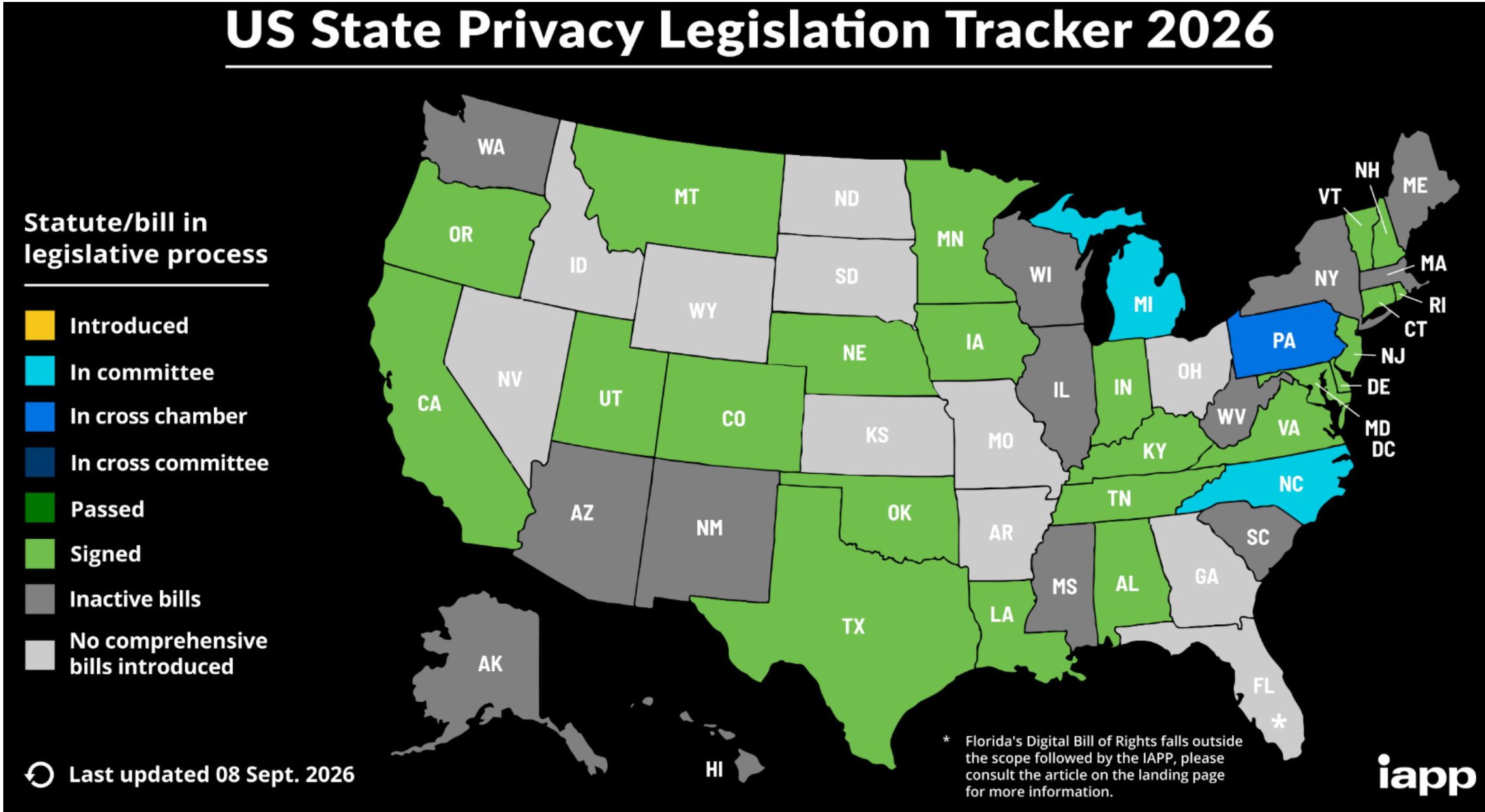
State & Other Requirements

More fun!

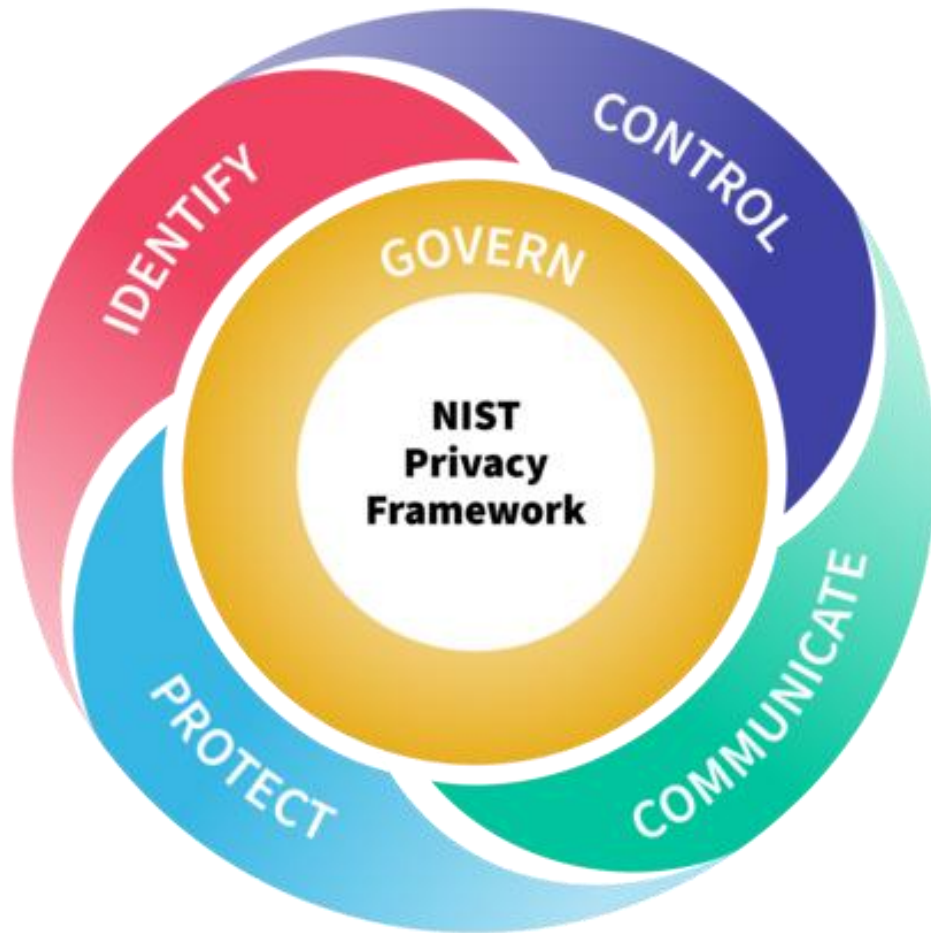
Legislation is here and more is coming

- Right to know
- Right to correction
- Right to be forgotten
- Right to data portability
- Right to restrict processing
- Right to no discrimination

US State Privacy Legislation Tracker 2026



Privacy – Build a Program



The NIST Privacy Framework 1.0

Use with NIST CSF to manage risk

v1.1 draft released 14 April 2025

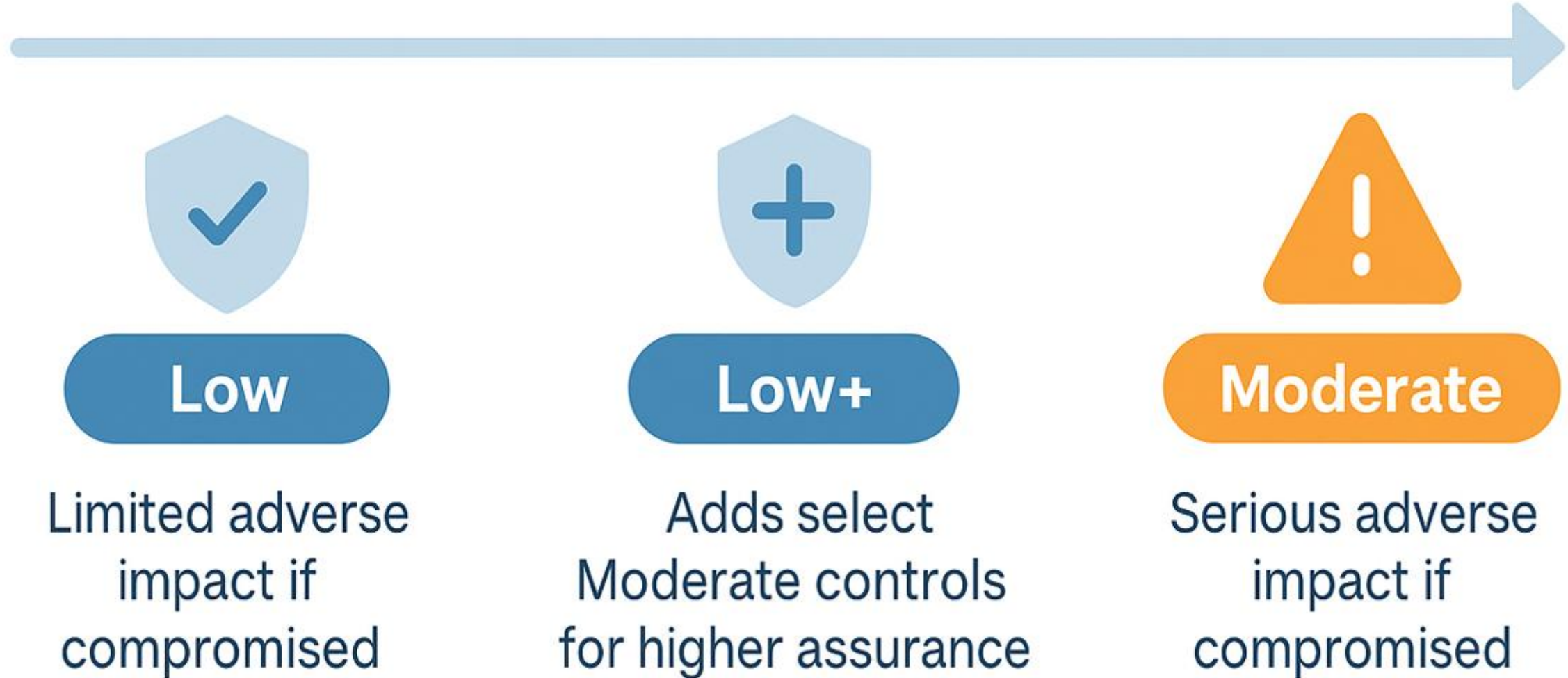
Final expected 2026

- **Third-Party Risk Management**

-

GovRAMP Security Categories

Agencies determine impact level based on data sensitivity and potential risk



Individual Government Membership

Stay Informed. Stay Connected.

For government professionals in IT, procurement, risk, or compliance roles. Get insights, resources, and peer collaboration to support secure technology adoption.

FREE

[View Benefits](#)

[Join Now](#)

Participating Government Membership

Modernize Procurement. Strengthen Security.

Designed for state, local, tribal, and territorial agencies adopting GovRAMP to standardize secure cloud procurement and reduce third-party risk.

FREE

[View Benefits](#)

[Apply Now](#)

The Payment Card Industry Security Standards Council (PCI SSC) is the governing body.

- PCI is a comprehensive security program for how merchants and service providers must handle card holder data (CHD).
- Sanctioned by the 6 major card brands:
 - Visa
 - Mastercard
 - Discover
 - JCB
 - American Express
 - Union Pay



Does PCI Apply to You?



ANY merchant that while conducting
credit card transactions
“Stores, Processes, or Transmits”
cardholder data
MUST comply with the
**Payment Card Industry Data Security
Standard (PCI-DSS).**

That includes Service Providers

Common Misconceptions

Myth 1

We outsource; therefore, we have no PCI compliance responsibility.

Myth 2

Our e-commerce website links to a gateway/processor page so it is completely out of scope.

Myth 3

We don't store CHD, so we are not required to comply or report.

Myth 4

We encrypt all CHD, so we are out of scope.

NOTE: It's a requirement to encrypt stored CHD!

It's all about the Scope.

Scope for PCI is all people, systems and processes that store, transmit, or process credit card information.

This also includes security systems.

Follow the Merchant ID

- A Merchant ID (MID) is usually issued by the acquiring bank to the merchant entity.
- Where and how the MID is used is the first step to determining scope.

Not your MID? PCI might not apply.



Use validated Point to Point Encryption

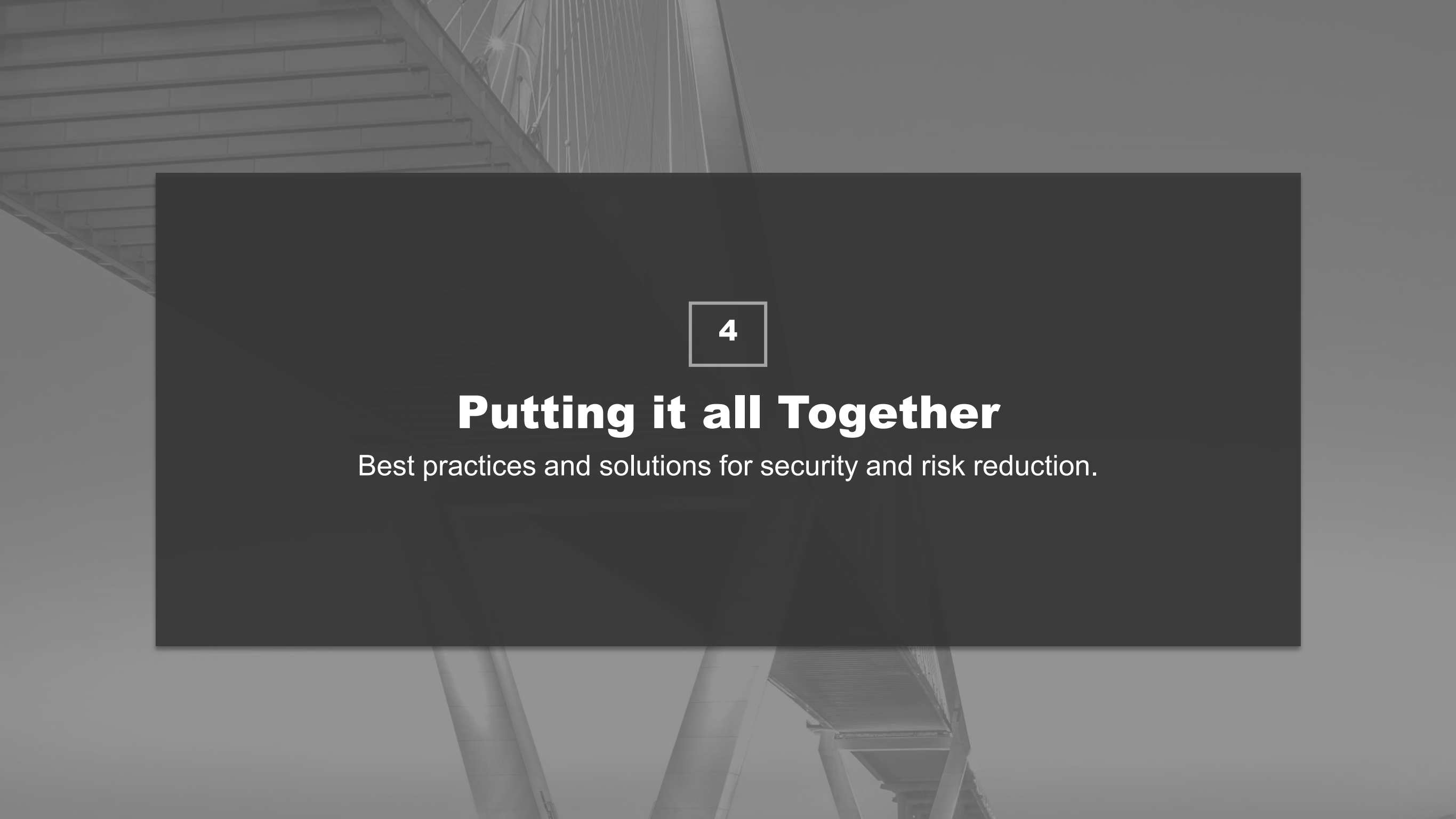


Validated P2PE is not infectious to other network devices.

This is the easiest, most cost-effective way to reduce scope.

E-Commerce Requirements in 4.0.1

- **6.4.3 - Ensure scripts are authorized, integrity checked**
 - Use a Content Security Policy
- **11.6.1 - Ensure HTTP headers and payment pages are authorized, integrity checked**
 - Use a reverse proxy/CDN
- **Outsource!**



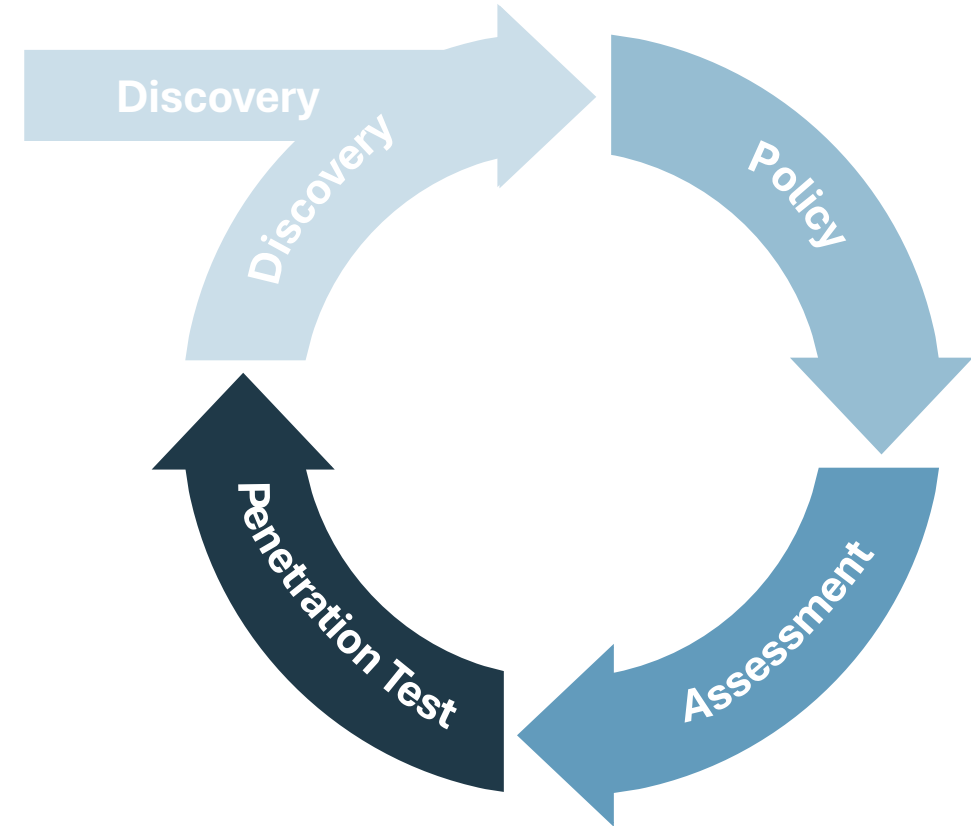
4

Putting it all Together

Best practices and solutions for security and risk reduction.

Key Elements of a Security Program

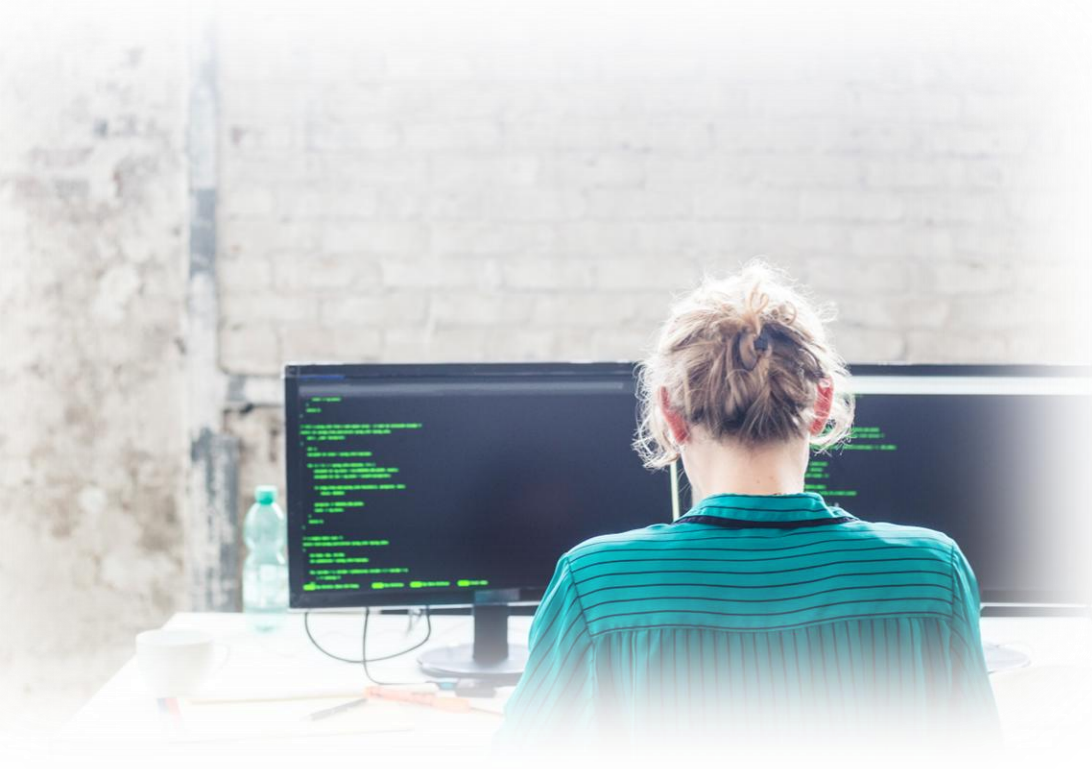
1. Data and Asset Discovery
2. Policy Creation/Review
3. Assessment
4. Penetration Test



Data Security Posture Management (DSPM)

A Foundation for Cybersecurity Maturity

- Builds and maintains a categorized data inventory
- Maps data across systems, cloud, and formats
- Aligns with privacy and compliance needs
- Supports data lifecycle governance
- Enables breach detection and notification



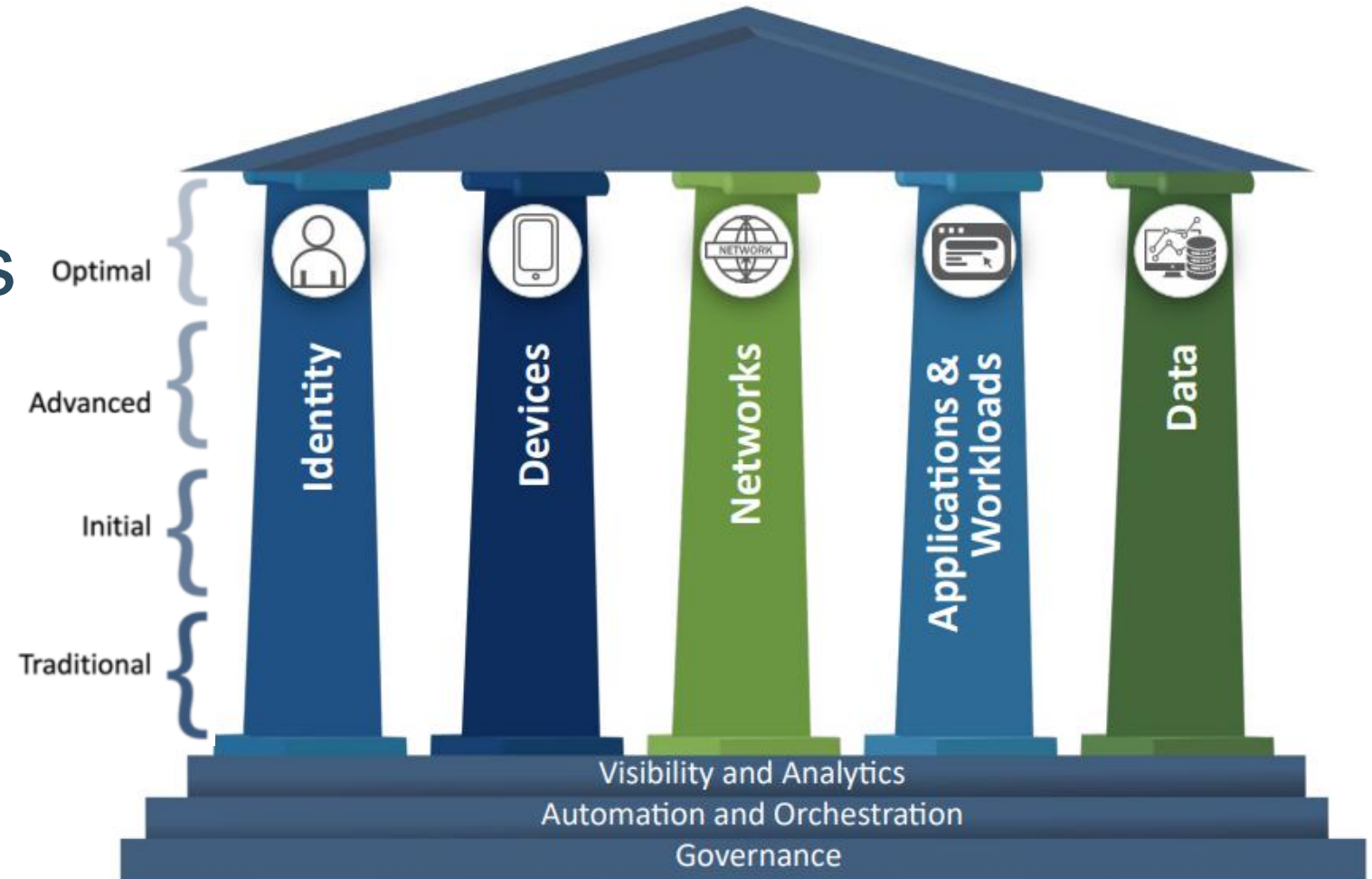
Risk Management

- **Define Key Objectives**
 - Financial, brand damage, staff
 - Appetite
 - Tolerance
 - Capacity
- **Maintain Risk Register**
- **Perform Recurring Risk Assessments**
- **Third Party Risk**
- **Fair Institute for Quantitative Risk**

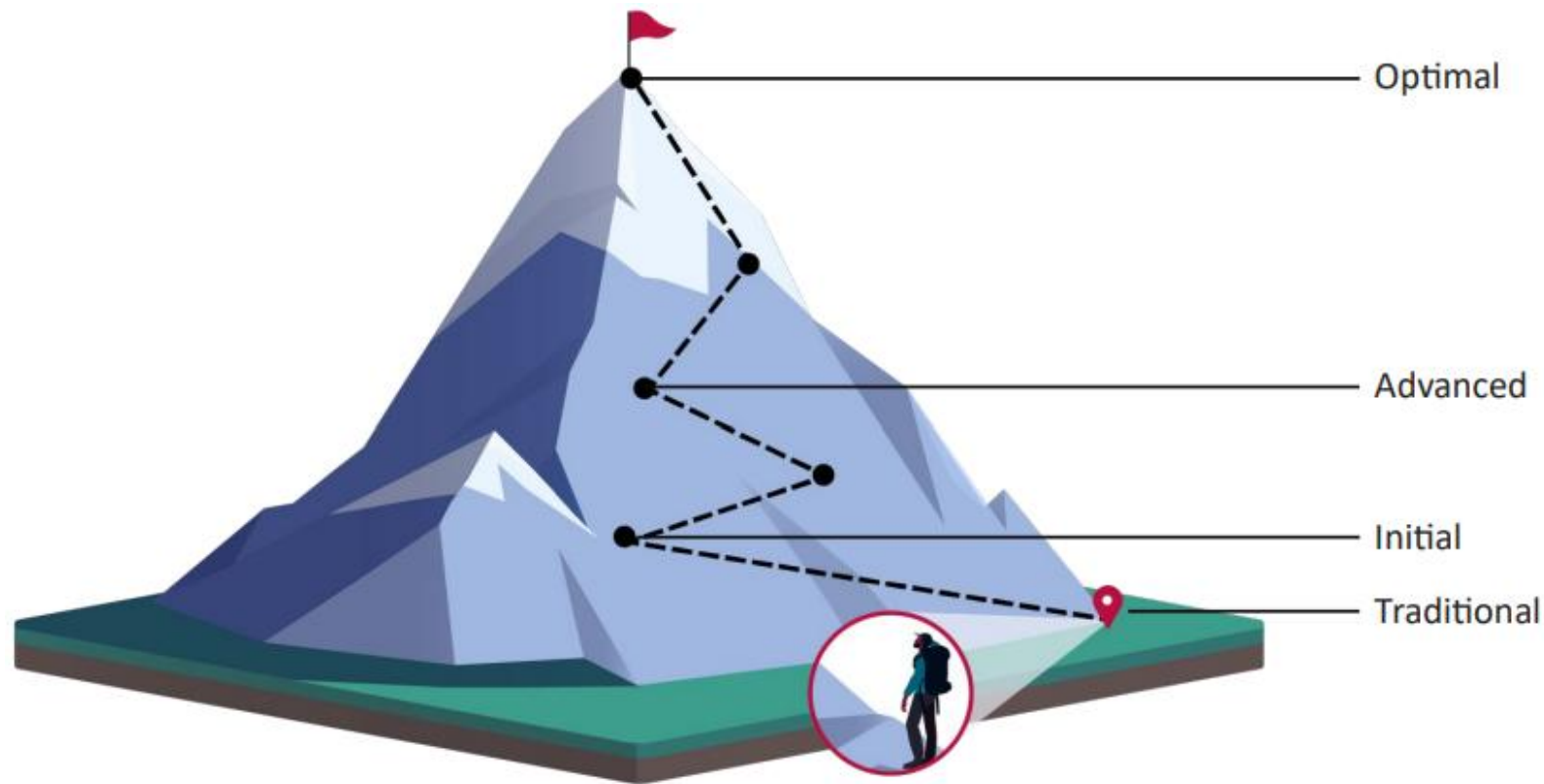


Zero Trust Effectiveness

- CISA Zero Trust Maturity Model v2.0 (ZTMM)
- Internal/3rd Party Assessment



ZTMM Example - Identity



Identity	Traditional	Initial	Advanced	Optimal
	Passwords or MFA	MFA with passwords	Phishing-resistant MFA	Continuous validation and risk analysis

Penetration Testing



- External
- Internal + Wireless
- **Social Engineering**
- Physical
- Applications and API
- On-premises and in the Cloud
- **MFA Replay and Phish Resistance**
- Vulnerability Assessment
- Change-Based

A black and white photograph of the Golden Gate Bridge, viewed from a low angle looking up at the tower and across the span. The bridge is shrouded in a thick layer of fog or mist, which fills the lower half of the frame. The sky is overcast and grey. The bridge's iconic lattice tower and suspension cables are clearly visible.

ARE THERE ANY QUESTIONS?



[Structured.com](https://structured.com)